RESTRICTED

QAYRAWAN INFORMATION SYSTEMS

AI Usage Policy

Organizational policy · ECC Compliance Program

Document ID	**QIS-POL-002**
Version	0.5 (Draft)
Date	10 November 2026
Classification	Restricted
Sharing signal	Amber · TLP:AMBER

Prepared by Naif Alsalem, GRC Lead

Issued in Arabic and English; if they conflict, the Arabic text prevails. QIS is a fictional company: its people and clients are invented for a professional portfolio by Naif Alsalem. The regulators and regulations cited are real.

RESTRICTED

Policy information

Policy name	AI Usage Policy
Policy code	QIS-POL-002
Policy owner	GRC Lead — Naif Alsalem
Prepared by	Naif Alsalem — GRC Lead
Date created	5 November 2026
Policy version	0.5 (Draft)
Implementing procedures	QIS-PRC-002 AI Usage Procedure

Sharing signal (Traffic Light Protocol)

This policy is marked under the Traffic Light Protocol (TLP) used in National Cybersecurity Authority documents at **Amber (TLP:AMBER)**. It may not be circulated beyond that level without the owner's approval.

● **Red** TLP:RED	Personal and confidential to the recipient only: it may not be shared with anyone inside or outside the recipient's organization beyond the stated recipients.
● **Amber** TLP:AMBER	**Limited sharing: the recipient may share it within their own organization, only with the people concerned and those who need to act on it. — the level set for this document**
● **Green** TLP:GREEN	Sharing within the same community: it may be shared within the organization, related organizations or the same sector, but not through public channels.
● **White** TLP:WHITE	Unlimited.

RESTRICTED

Change log

Version	Date	Changed by	Reason for change
0.1	5 Nov 2026	Naif Alsalem	First draft, with the policy and procedure in one document.
0.2	9 Nov 2026	Naif Alsalem	Information-security markings added: classification in the header, a watermark, and the sharing signal in the footer.
0.3	9 Nov 2026	Naif Alsalem	Rebuilt on QIS's policy template, with clauses based on the NCA AI Cybersecurity Guidelines (AICG-1:2026) and the SDAIA AI First policy; implementing steps moved to QIS-PRC-002.
0.4	9 Nov 2026	Naif Alsalem	New visual identity and cover, readability, and the four sharing levels used in NCA documents.
0.5	10 Nov 2026	Naif Alsalem	Change log corrected (the 0.4 entry had been placed in the approvals table), classification badge centred and coloured by level, watermark coloured, and the company's Arabic name updated. English version translated from the Arabic lead text.

Document approval

Role	Job title	Name	Date	Signature
Owner	GRC Lead	Naif Alsalem	—	—
Reviewer	Chief Technology Officer	Reem Al-Otaibi	—	—
Reviewer	Head of Service Delivery	Sultan Al-Dossary	—	—
Reviewer	Chief Financial Officer (contracts and HR)	Majed Al-Qahtani	—	—
Endorser	Chair, Cybersecurity Steering Committee	Faisal Al-Harbi	—	—
Approver	Chief Executive Officer	Faisal Al-Harbi	—	—

Review schedule

Review frequency	Last review	Next review
Every six months in the first year, then annually	—	May 2027

RESTRICTED

RESTRICTED

Policy classification

Top Secret	The policy is classified "Top Secret" if unauthorized access to it or disclosure of it or its content would cause serious damage that cannot be remedied or repaired.
Secret	The policy is classified "Secret" if unauthorized access to it or disclosure of it or its content would cause serious damage. This applies to sensitive information that defines how QIS operates.
Restricted	**The policy is classified "Restricted" if unauthorized access to it or disclosure of it or its content would cause limited damage. This applies to information not approved for general circulation outside QIS.**
Public	The policy is classified "Public" when unauthorized access to it or disclosure of its content would have no effect on QIS. This applies to documents approved for public release.

Confidentiality of the policy

This policy is a Qayrawan Information Systems document classified Restricted. It may be circulated only to QIS staff and to the government clients under contract who need to see it. It may not be published, changed or shared, in whole or in part, with anyone unauthorized without the prior written approval of the policy owner.

RESTRICTED

Contents

1. Terms and definitions
2. Introduction
3. Purpose
4. Scope
5. Compliance with the policy
6. Roles and responsibilities
    6.1 Responsibility matrix (RACI) · 6.2 Assigning AI governance
7. Principles
    7.1 Transparency · 7.2 Fairness · 7.3 Privacy · 7.4 Assets
8. Policy clauses — AI Cybersecurity Guidelines (AICG-1:2026)
9. Alignment with the AI First policy
10. Key performance indicators (KPIs)
11. Key risk indicators (KRIs)
12. Consequences of non-compliance
13. Contact
14. Review and update
15. References

RESTRICTED

1. Terms and definitions

Term	Definition
Artificial intelligence (AI)	Computer technologies and systems able to imitate human intelligence, such as learning, analysis and decision-making, to carry out specific tasks.
Approved AI tool	A tool listed in the register of approved AI tools after being assessed under procedure 1 of QIS-PRC-002, with its permitted uses and the highest data classification that may be entered into it.
Client data	Any data, code, documents or configuration belonging to Clients A to F, whatever its classification.
Sensitive data	Data that needs a high level of protection, such as personal data, citizen data and classified data, whose leak could harm individuals, clients or QIS.
Prompts	The text and files a user enters into an AI tool.
Prompt injection	An attempt to steer an AI model through crafted input so it ignores its instructions or reveals data.
AI agent	An AI system that carries out actions or calls tools and services on the user's behalf with some independence.
Human oversight	Review of AI outputs and follow-up of its decisions by a qualified person, to make sure they are accurate, prevent errors and confirm the controls are followed.
Transparency	The principle that how AI systems work is clear, their outputs can be understood, and their use is disclosed when needed.
Fairness	The principle that AI systems treat everyone they serve without unjustified bias or discrimination.
Privacy	The principle of protecting personal data from unauthorized access or use, and using it only for legitimate purposes.
Least privilege	The principle of giving users, systems and agents only the access they need to do their tasks.
Data loss prevention (DLP)	Technology that prevents sensitive data from leaking, being lost or being accessed without authorization.
Vulnerabilities	Weaknesses in systems, applications or infrastructure that could be exploited to threaten information security.
Business continuity management	A management framework that keeps critical operations running during and after a disruption, and restores them within an acceptable time.
Key performance indicator (KPI)	A measure of how well targets are met and how processes and controls perform.

RESTRICTED

Term	Definition
Key risk indicator (KRI)	A measure that gives early warning when a risk approaches the limits of risk appetite.
Personal Data Protection Law (PDPL)	The Saudi law that governs the collection, processing, storage and sharing of personal data, and its implementing regulation.
Policy	An approved, formal document setting the principles and rules that govern how QIS works.
Procedure	An implementing document under a policy that sets the steps, owner, outputs, time limits and records for a piece of work.

2. Introduction

Qayrawan Information Systems provides managed IT, hosting and software development services to government clients, and its staff increasingly use AI tools to write code, prepare documents and analyze data. These tools offer real gains in efficiency and quality, but they carry particular risks for government clients' data and systems: data leaking through prompts, insecure code entering client systems, and reliance on inaccurate outputs. This policy sets the framework for using AI at QIS, so that client data is protected, AI is used responsibly, and QIS meets national law, the requirements of the National Cybersecurity Authority and the Personal Data Protection Law.

3. Purpose

This policy governs the use of AI technologies at QIS and in the systems it develops or hosts for its clients, so that they are used safely and responsibly, data and information are protected, the risks of these technologies are reduced, efficiency improves, and the applicable national laws and regulations are met.

4. Scope

- All QIS staff and contractors who use AI tools in QIS's or clients' work.
- All AI systems, tools and models used at QIS, including coding assistants and generative AI tools.
- AI features that QIS builds or adds to the systems it develops or hosts for clients.
- Providers of AI tools and services that QIS works with.
- Every stage of the AI life cycle: request, development, use, processing, storage, sharing and shutdown.

5. Compliance with the policy

The GRC Lead must ensure QIS complies with this policy, and every department concerned must apply it. Its clauses are carried out through the procedures in QIS-PRC-002.

6. Roles and responsibilities

Role	Responsibilities
Chief Executive Officer	Approves the policy and keeps it aligned with QIS's strategic goals, takes the top decisions in critical cases, and approves adding AI features to client systems.
Cybersecurity Steering Committee	Endorses the policy, approves high-impact use cases, accepts residual risks, and follows the quarterly compliance reports.
GRC Lead	Writes and reviews the AI policies, manages the register of approved tools and the AI risk register, assesses compliance, and reports and escalates.
Security Operations and Engineering	Assesses and tests the cybersecurity risks of AI systems, monitors logs through the managed security operations centre, and leads the response to AI incidents.
Chief Technology Officer	Oversees the running of AI tools and their environments, applies access, security settings and logging, and supports recovery.
Development team	Applies secure development requirements, and reviews and tests AI-generated code before merging it.
Head of Service Delivery	Coordinates with clients on any use of AI on their data or systems, and obtains their written approval.
Chief Financial Officer	Puts AI clauses into staff and supplier contracts, and follows disciplinary action with HR.
All staff and contractors	Follow the policy, use only approved tools within their permitted uses, and report any incident at once.

6.1 Responsibility matrix (RACI)

CEO: Chief Executive Officer · Committee: Cybersecurity Steering Committee · GRC: Governance, Risk and Compliance · SecOps: Security Operations and Engineering · CTO: Chief Technology Officer · Dev: Development team · Delivery: Service Delivery

R — Responsible · A — Accountable · C — Consulted · I — Informed

RESTRICTED

Activity	CEO	Committee	GRC	SecOps	CTO	Dev	Delivery
Approving the policy and its updates	A	C	R	C	C	I	I
Approving a new AI tool	I	A	R	C	C	I	I
Managing the tool and use-case register	I	I	A/R	C	C	I	I
Classifying data before use	I	I	A	C	R	C	C
Adding an AI feature to a client system	A	C	R	C	R	R	C
Managing access and permissions	I	I	C	A	R	I	I
Responding to AI incidents	I	I	C	A/R	R	C	C
Measuring the indicators (KPIs / KRIs)	I	C	A/R	C	C	I	I
Training and awareness	I	I	A/R	C	I	I	I
Testing recovery and continuity plans	I	I	C	A	R	I	C

6.2 Assigning AI governance

Added clause — Qayrawan Information Systems

This clause does not appear in the external reference documents. It was added because QIS has no separate AI unit, so the policy is assigned to existing units under the Cybersecurity Charter QIS-CHR-001.

QIS-ORG-1	AI governance is assigned to the Governance, Risk and Compliance unit within the cybersecurity function. It covers writing policies, managing the register of approved tools and the risk register, assessing compliance, and reporting to the Steering Committee.
QIS-ORG-2	The Chief Technology Officer runs the AI tools and their environments, and the development team applies the secure development requirements.
QIS-ORG-3	Those who implement (IT and Development) are kept separate from those who assess (Governance, Risk and Compliance), to prevent conflicts of interest in approving tools and use cases and in assessing compliance.
QIS-ORG-4	The RACI is updated when a Head of Cybersecurity is appointed under the transition plan in QIS-CHR-001, and an update to this policy records it.

RESTRICTED

7. Principles

7.1 Transparency

The use of AI must be disclosed to the client whenever the contract requires it or the output is aimed at citizens, and outputs must be traceable and their basis understandable.

7.2 Fairness

AI features must not be used in decisions that affect citizens without bias testing and the client's approval, and everyone served must be treated equally.

7.3 Privacy

Data privacy must be protected when using AI: client data and personal data may not be entered into tools not approved for them, and may not be used to train any model.

7.4 Assets

Every tool, model and API key must be recorded in the asset register, and the departments concerned informed of any change to them.

These principles are consistent with the AI Ethics Principles issued by the Saudi Data and AI Authority.

8. Policy clauses — AI Cybersecurity Guidelines

QIS applies the AI Cybersecurity Guidelines (AICG-1:2026) issued by the National Cybersecurity Authority, made up of four main components, fifteen subcomponents and forty-two controls. They appear below with their reference numbers and text, and each subcomponent is followed by QIS's own implementation requirements, coded QIS, which set out how they are applied without changing the controls themselves. The control text is a working English translation of the Arabic draft.

No.	Main component	Subcomponents	Controls
1	Cybersecurity Governance	4	13
2	Cybersecurity Defense	9	24
3	Cybersecurity Resilience	1	1
4	Third-Party Cybersecurity	1	4

RESTRICTED

1 Cybersecurity Governance

1-1 Cybersecurity Risk Management

Objective: To manage the cybersecurity risks of AI under a clear methodology, protecting the organization's information and technology assets, in line with its policies and procedures and the applicable laws and regulations.

No.	Controls
1-1-1	Identify, document and approve cybersecurity risk management practices for every stage of the AI system life cycle, then implement them.
1-1-2	Carry out a cybersecurity risk assessment to classify AI system agents by potential impact, likelihood and reversibility, and apply suitable cybersecurity measures.

Additional implementation requirements — Qayrawan Information Systems

QIS-1-1-1	AI risks are assessed under the risk management methodology QIS-RMM-001, recorded in the risk register QIS-RR-001 in a separate category, and reviewed every three months.
QIS-1-1-2	Acceptance of residual risk by the risk owner is documented under the acceptance authority in QIS-RMM-001 before release to production or into any client system.
QIS-1-1-3	Risks are reassessed after any significant change to the model, data source or scope of use, or within twelve months of the last assessment, whichever comes first.

1-2 Cybersecurity in Information and Technology Project Management

Objective: To build the cybersecurity requirements of AI into the management of information and technology projects throughout the AI system life cycle.

No.	Controls
1-2-1	Apply security by design, and define and carry out procedures to secure the development and operation of AI: from setting cybersecurity requirements, obtaining data from trusted and secure sources, training and tuning models and setting up prompt configurations, to evaluating, deploying, operating and maintaining models, and finally retiring and securely disposing of them.
1-2-2	Treat data returned from external tools, memory stores or third-party APIs as untrusted, and validate and sanitize anything entered into the context window, to stop malicious instructions disguised as data from running.
1-2-3	Avoid retraining models or uncontrolled learning in the live environment without direct controls and the necessary justification, and carry out a cybersecurity risk assessment.

RESTRICTED

No.	Controls
1-2-4	Assess the cybersecurity capabilities and resilience of AI agents during their development and operation.
1-2-5	Review, test and formally approve all AI-generated code in a systematic way, to treat cybersecurity risks before it is used in development, integration or production environments.
1-2-6	Define and apply approval procedures for high-impact AI system projects before they are deployed to production, making sure their cybersecurity risks are assessed and treated.
1-2-7	Grant AI agents autonomy gradually, with continuous human oversight to monitor and understand their cybersecurity-related decisions and actions.

Additional implementation requirements — Qayrawan Information Systems

QIS-1-2-1	A mandatory security review gate is held at the end of each stage of client projects that include AI in their scope or development tools, and the decision to approve or reject is recorded with its reasons.
QIS-1-2-2	All AI-generated code goes through peer review, security scanning and dependency scanning in the build pipeline before it is merged into client repositories, and is not merged without them.
QIS-1-2-3	Development, test and production environments are separated, and real client data may not be used in development environments unless it is anonymized and the client has approved.

1-3 Cybersecurity in Human Resources

Objective: To manage the AI-related cybersecurity risks and requirements concerning staff (employees and contractors) effectively before, during and at the end of their work, in line with the organization's policies and procedures and the applicable laws.

No.	Controls
1-3-1	Screen staff who can access internal components of AI systems, or who have privileged access to AI operating environments or other high-risk AI tasks.
1-3-2	Ensure confidentiality, acceptable use and safe handling by all staff whose roles may expose sensitive data, or the prompts, outputs or settings of AI systems.

Additional implementation requirements — Qayrawan Information Systems

QIS-1-3-1	Acceptable-use clauses for AI are included in staff and contractor contracts and confidentiality undertakings, with an annual acknowledgement.
QIS-1-3-2	All AI-related access is removed at once when a contract ends or a role changes, including accounts on external tools and API keys.

RESTRICTED

1-4 Cybersecurity Awareness and Training Program

Objective: To make sure specialists and users receive AI cybersecurity awareness and training suited to their roles and to the cybersecurity risks of AI systems.

No.	Controls
1-4-1	Include AI cybersecurity requirements in training for staff who develop, configure or run AI systems, covering: secure design of prompts and tools, handling outputs, reporting incidents, safe handling of sensitive data in prompts and uploaded files, recognizing AI-specific threats such as prompt injection and data leakage, and checking outputs.
1-4-2	Include awareness of AI system cybersecurity in the organization's overall cybersecurity awareness program, covering: safe use of prompts and avoiding sensitive information in them, and the risks of AI-generated software and the controls for reviewing and testing it before use.

Additional implementation requirements — Qayrawan Information Systems

QIS-1-4-1	Every employee and contractor completes a short training on this policy before being given any approved tool, new joiners within thirty days of starting, with an annual refresher.
QIS-1-4-2	Prompt injection and data leakage simulation exercises are run for the development and managed services teams, and their results reported to the Steering Committee.
QIS-1-4-3	An up-to-date internal reference is available showing the approved tools, the data allowed in each, and examples of permitted and forbidden use.

2 Cybersecurity Defense

2-1 Asset Management

Objective: To make sure the organization has an accurate and detailed register of its AI-related information and technology assets, supporting cybersecurity and operational requirements and keeping those assets confidential, intact and available.

No.	Controls
2-1-1	Create an asset inventory of all AI system components, and keep it continuously up to date.
2-1-2	Identify the asset owner and life-cycle status of all AI system components, including experimental, pre-deployment, production, restricted and retired assets, and services and settings.

RESTRICTED

No.	Controls
2-1-3	Define and carry out procedures for assets and components after AI systems are retired and for the post-operation stage, such as secure disposal.

Additional implementation requirements — Qayrawan Information Systems

QIS-2-1-1	The register of approved AI tools is linked to the asset register QIS-AST-001, and updated within five working days of any addition, change or retirement.
QIS-2-1-2	Each asset has a business owner and a technical owner, and is linked to the clients it serves.
QIS-2-1-3	The supply chain of each model or library (source, licence and dependencies) is recorded in the AI bill of materials (AI-BOM).

2-2 Identity and Access Management

Objective: To ensure secure, restricted logical access to AI-related information and technology assets, preventing unauthorized access and limiting access to authorized users, services and AI agents only, and only when they need it for their tasks.

No.	Controls
2-2-1	Define permissions and authorization policies by task for human user accounts, service accounts and AI agent accounts, applying segregation of duties, least privilege and need-to-know and need-to-use.
2-2-2	Review periodically the identities, access rights, tokens and service accounts used by AI systems.
2-2-3	Be able to control permissions in ways that reduce AI-related risks, including rate limiting, usage thresholds and other mechanisms, to reduce the risks of model extraction and data leakage.

Additional implementation requirements — Qayrawan Information Systems

QIS-2-2-1	Multi-factor authentication and single sign-on are required for all access to approved AI tools and for all administrative access to their components.
QIS-2-2-2	API keys are managed in the secrets vault: issued, rotated every ninety days and revoked at once on suspicion, and may not be stored in code or repositories.
QIS-2-2-3	Every AI agent account is linked to an accountable human owner, and shared or ownerless accounts are not allowed.

RESTRICTED

2-3 Network Security Management

Objective: To secure the network paths, interfaces and communications used by AI systems, including traffic for training, tuning, retrieval and inference, and communications with external tools and services.

No.	Controls
2-3-1	Isolate the network of AI systems' internal components from external components, and limit protocols, ports, destinations and egress paths to approved requirements only, to enforce trust boundaries and detect unusual activity.
2-3-2	Isolate the network of AI systems' external components, limit access to and communication with them to operational need only, and apply suitable controls to protect internet-facing systems, reduce the attack surface and detect unusual activity.

Additional implementation requirements — Qayrawan Information Systems

QIS-2-3-1	An allow-list of approved AI service destinations is kept, and all others are blocked by default on QIS's network and devices.
QIS-2-3-2	Neither the remote management tool nor client networks connect to any external AI service without the client's written approval.

2-4 Data and Information Protection

Objective: To protect the data and information that AI systems use, produce or are linked to in any way, across its whole life cycle.

No.	Controls
2-4-1	Protect the confidentiality and integrity of AI system component data, including training and evaluation data, model weights, prompts, embeddings, logs, contexts and outputs, at rest, in transit and in processing, and limit access to and disclosure of it to authorized people only.
2-4-2	Protect classified data within AI systems at rest, in transit and in processing, according to its classification under the applicable laws and regulations.
2-4-3	Protect AI memory components from unauthorized change, and check the integrity of stored content, to prevent memory poisoning and manipulation.
2-4-4	Define and apply guardrails that detect malicious input, unauthorized actions, sensitive information and other threats, and make sure they are tested before deployment and after significant changes.

RESTRICTED

Additional implementation requirements — Qayrawan Information Systems

QIS-2-4-1	Each approved tool has a highest data classification that may be entered into it. Client data is entered into a tool only with the client's written approval and only in a tool hosted inside the Kingdom, and data classified Restricted or higher, passwords and keys are never entered into any tool.
QIS-2-4-2	AI tool providers agree by contract not to use QIS's or its clients' data to train their models, and this is recorded in the service agreement.
QIS-2-4-3	Data loss prevention is applied to traffic going to AI services, and its alerts are reviewed monthly.
QIS-2-4-4	Retention periods are set for prompt and output logs, and the logs are securely disposed of when the period ends.

2-5 Backup and Recovery Management

Objective: To make sure there are secure arrangements for backing up, restoring and rolling back AI systems.

No.	Controls
2-5-1	Apply secure backup and recovery mechanisms to keep AI systems available and reliable, and make sure they can be restored within the set time.
2-5-2	Test the backup, recovery and rollback procedures for AI systems periodically.

Additional implementation requirements — Qayrawan Information Systems

QIS-2-5-1	Configuration files, prompt libraries and knowledge sources for AI features in client systems are included in the backup scope approved in QIS-BCP-001.
QIS-2-5-2	A restorable copy of the last two approved versions of every AI feature in operation is kept, to allow a fast rollback if performance degrades or an incident occurs.

2-6 Vulnerability Management

Objective: To identify, assess, treat and report in good time the vulnerabilities that affect AI models, applications, infrastructure, dependencies and integrations.

No.	Controls
2-6-1	Identify, track and treat vulnerabilities in AI systems.
2-6-2	Subscribe to proactive vulnerability and threat intelligence services for AI systems, and monitor security advisories from developers, service status updates and cybersecurity alerts.
2-6-3	Disable or restrict AI features when a cybersecurity vulnerability is found, until the fix is in place and verified.

RESTRICTED

Additional implementation requirements — Qayrawan Information Systems

QIS-2-6-1	Vulnerabilities are fixed within the maximum times set by severity in QIS's vulnerability management policy, and overruns are escalated to the policy owner.
QIS-2-6-2	Open-source AI library dependencies are scanned automatically in the build pipeline, and merging is blocked when critical vulnerabilities are found.

2-7 Penetration Testing

Objective: To assess how well the cybersecurity guidelines protecting AI systems work, by simulating relevant attack and threat techniques to find exploitable vulnerabilities, misconfigurations and weaknesses before and after launch, in proportion to the risk level, the systems' complexity and their exposure to threats.

No.	Controls
2-7-1	Carry out penetration tests of AI system components, and AI-specific penetration tests, before deployment and periodically, so that outputs and system behaviour are tested.
2-7-2	Test AI systems in different ways, such as red-teaming, adversarial evaluation and checking human override procedures.
2-7-3	Treat the findings and vulnerabilities found by cybersecurity tests and assessments, and define suitable hardening measures.

Additional implementation requirements — Qayrawan Information Systems

QIS-2-7-1	A penetration test is carried out before any AI feature is launched in a client system, then at least once a year and after every significant change.
QIS-2-7-2	Testing is assigned to a team independent of the development team, and retesting confirms the fix before findings are closed.

RESTRICTED

2-8 Cybersecurity Event Logs and Monitoring Management

Objective: To make sure logging, monitoring and detection cover AI-specific events, actions, changes and unusual behaviour, supporting compliance, incident response and continuous verification.

No.	Controls
2-8-1	Log and monitor cybersecurity events on AI system components, including identity and access events, critical events on assets, access to data sets and knowledge sources, configuration changes, and the enabling of components and tools.
2-8-2	Log and monitor cybersecurity events linked to actions taken by AI systems, including uploading and downloading data, creating, changing or deleting data, and any action that could affect integrity, confidentiality or availability.

No.	Controls
2-8-3	Protect, keep and analyze AI logs relevant to cybersecurity, to support compliance monitoring, incident response, and the treatment and investigation of vulnerabilities.

Additional implementation requirements — Qayrawan Information Systems

QIS-2-8-1	AI system logs are kept for at least twelve months, or longer if the contract requires, with time synchronized from a single source.
QIS-2-8-2	Logs are sent to the managed security operations centre, and specific detection cases are defined for unusual behaviour in AI tools.
QIS-2-8-3	Traceability is enabled in AI features in client systems, so each output is linked to its input, the user who requested it and the model version that produced it.

2-9 Web Application Security

Objective: To make sure AI-backed applications, APIs, web interfaces, agents, software components and their integrations are designed, developed, configured and run securely.

No.	Controls
2-9-1	Protect web applications and services linked to AI systems with secure communication protocols, request rate limits, protection against denial-of-service attacks, controlled exit points, and filters that block insecure channels.

Additional implementation requirements — Qayrawan Information Systems

QIS-2-9-1	AI interfaces open to citizens in client systems are separated from internal interfaces, with different authentication policies for each.
QIS-2-9-2	Every client system with an AI feature aimed at citizens shows a clear notice that the user is dealing with an AI system, and the limits of relying on its outputs.

3 Cybersecurity Resilience

3-1 Cybersecurity Resilience Aspects of Business Continuity Management

Objective: To make sure cybersecurity resilience requirements are part of the organization's business continuity management, and that the effects on AI systems of disasters caused by cyber risks are addressed in proportion to their importance and how much the organization relies on them.

No.	Controls
3-1-1	Define rollback and safe shutdown procedures, and alternatives, for AI systems in the event of a cybersecurity incident, where possible.

Additional implementation requirements — Qayrawan Information Systems

QIS-3-1-1	The impact of AI features failing in client systems is included in the business impact analysis in QIS-BCP-001, with a recovery time objective and recovery point objective for each.
QIS-3-1-2	A manual operating alternative is prepared for every client service that depends on AI, and tested every year.

4 Third-Party Cybersecurity

4-1 Third-Party Cybersecurity

Objective: To identify, assess, manage and continuously monitor the cybersecurity risks arising from third-party organizations, components or services used in the AI life cycle.

No.	Controls
4-1-1	Assess and treat the cybersecurity risks that may arise from third parties' use of AI systems.
4-1-2	Assess the cybersecurity of third-party AI components in AI systems before use and on an ongoing basis.
4-1-3	Make sure AI developers meet the organization's AI cybersecurity requirements under their contracts, and monitor and assess this periodically.
4-1-4	Define exit, transfer and secure disposal or destruction requirements for AI system components when the developer changes or the contract ends.

Additional implementation requirements — Qayrawan Information Systems

QIS-4-1-1	Each AI tool provider is assessed before approval on: where data is processed and hosted, how long inputs are kept, its commitment not to train on them, its security controls and its contract terms. The assessment is repeated every year.
QIS-4-1-2	Provider contracts include the right to audit and incident notification within a set time, and the risk of depending on a single provider is assessed.
QIS-4-1-3	A documented exit plan is prepared for each provider, covering data recovery, service transfer and confirmation of secure disposal at the provider.

9. Alignment with the AI First policy

The AI First policy was issued by the Saudi Data and AI Authority for public entities. QIS is not a public entity, but it aligns its practices with the policy because its clients are government entities bound by it, and because contracts may require it. The clauses drawn

from it follow, numbered by article, each followed by QIS's own implementation requirements, coded QIS.

9.1 Areas of application (Article 6)

9.1.1	Priority in applying the AI First approach goes to areas where AI adds value by raising productivity, improving quality, lowering costs or improving the user experience, including: business planning and workforce organization, with review and approval staying with people; designing services and developing processes so AI's potential is considered from the earliest design stages; and planning procurement and contracting, within what the law allows.
9.1.2	The entity may apply the approach in other areas where this fits the policy's principles, is shown to be suitable and worthwhile, and can deliver clear organizational value.
9.1.3	Areas of application do not include token or experimental uses with no clear organizational value, nor simply acquiring tools or technical solutions without real use or measurable effect.

Additional implementation requirements — Qayrawan Information Systems

QIS-9.1.1	The Steering Committee approves an annual list of priority areas for applying AI at QIS, ranked by expected value and readiness.
QIS-9.1.2	Each proposed use case needs a short statement of the problem, the non-technical alternative, the expected value and the running cost, and cases whose effect cannot be measured are rejected.

9.2 Principles (Article 7)

9.2.1	Empowering people: people are at the centre of the transformation, through raising staff awareness and enabling them to use AI effectively.
9.2.2	Value before technology: AI is adopted where it is shown to be suitable and worthwhile compared with other options, with attention to resource efficiency and avoiding complexity.
9.2.3	Gradual adoption: AI is applied step by step, starting with the areas of highest priority or readiness, then expanding with needs and capabilities.
9.2.4	Responsible use: consistency with national AI governance rules is maintained, to ensure safe use, protect rights and limit negative effects.
9.2.5	Data sovereignty: national laws on data and cybersecurity are followed, so that national data is protected and processed securely and compliantly.

Additional implementation requirements — Qayrawan Information Systems

QIS-9.2.1	A final human decision is kept in every process that affects citizens or the client's legal obligations, and the approver's name and the approval date are recorded.

RESTRICTED

QIS-9.2.2	Adoption of any new tool or feature starts with a pilot of set scope, duration and success criteria, and is widened only after those criteria are met.
QIS-9.2.3	Client data is processed and stored inside the Kingdom, and the processing location of every tool and service is recorded.

9.3 Pillars (Article 8)

9.3.1	Strategic and organizational direction: a clear vision and goals linking AI adoption to organizational priorities, frameworks that set out roles and responsibilities, and an administrative unit for AI that handles internal follow-up.
9.3.2	Organizational enablers: suitable people, data that is ready, of good quality and governed, with personal data protected across the model's whole life cycle, and use of the national AI infrastructure.
9.3.3	Practical results: applications that move from trial to lasting use, and a tangible effect on performance measured by indicators such as the number of use cases and the effect achieved.

Additional implementation requirements — Qayrawan Information Systems

QIS-9.3.1	The Governance, Risk and Compliance unit acts as the AI unit under clause 6.2, and reports regularly to the Steering Committee.
QIS-9.3.2	Any data set used for AI must have a named owner, a classification level, an approved purpose of use, and the client's approval if it is the client's data.

9.4 Follow-up (Article 9)

9.4.1	The AI administrative unit follows up regularly on the application of the policy and its related initiatives and applications.
9.4.2	Overall progress at national level is tracked using the National AI Index.

Additional implementation requirements — Qayrawan Information Systems

QIS-9.4.1	A central register of use cases and approved tools is kept, with status, owner, last assessment date and measured effect, and follow-up reports go to the Steering Committee every three months.

9.5 General provisions (Article 10)

9.5.1	The policy complements the laws, decisions and instructions in force, and does not override them.
9.5.2	The policy works together with the frameworks, guides, tools and indicators issued by the Authority and other competent bodies.

RESTRICTED

Additional implementation requirements — Qayrawan Information Systems

QIS-9.5.1	This policy is updated within ninety days of any national legal or regulatory update that affects its provisions.
QIS-9.5.2	Where this policy conflicts with another internal document or a client's contractual requirement, the text with the stricter protection applies, and the case is raised with the Steering Committee.

10. Key performance indicators (KPIs) for AI use

Code	Indicator	Target	Frequency
KPI-01	AI tools used at QIS that are listed in the register of approved tools	100%	Quarterly
KPI-02	AI-generated code that passed review and security scanning before merging	100%	Monthly
KPI-03	AI incidents contained within the time set in QIS-PRC-002	95%	Monthly
KPI-04	AI features in client systems with an approved risk assessment before going live	100%	Monthly
KPI-05	Staff and contractors who completed training on this policy	95%	Half-yearly
KPI-06	Providers of approved tools reassessed in the past twelve months	100%	Quarterly

11. Key risk indicators (KRIs) for AI use

Colour key (RAG status)

Colour	Status	Meaning and required action
Green	**On target / acceptable**	The indicator is within the acceptable threshold. Routine monitoring continues.
Amber	**Needs attention**	The indicator has passed the acceptable limit and needs immediate follow-up and correction within the set period.
Red	**At risk / non-compliant**	The indicator has passed the critical threshold and needs immediate escalation to senior management and an urgent treatment plan.

RESTRICTED

Code	Indicator	Threshold	Frequency
KRI-01	Unapproved AI services seen in network traffic	Green: 0 · Amber: 1 to 3 · Red: 4 or more	Monthly
KRI-02	Cases of client data or personal data entered into AI tools without approval	Red: any case	Monthly
KRI-03	Vulnerabilities in AI components not fixed within the set time	Amber: 1 · Red: 2 or more	Monthly
KRI-04	AI features running in client systems without an approved risk assessment	Red: any case	Quarterly
KRI-05	API keys not rotated within ninety days	Amber: 1 · Red: 2 or more	Monthly
KRI-06	Decisions affecting citizens that relied on AI outputs without documented human oversight	Red: any case	Quarterly

12. Consequences of non-compliance

Staff or contractors who do not comply with this policy may face disciplinary action under QIS's internal regulations, including a formal warning, restriction or removal of access, temporary suspension, and up to termination of employment or contract. Entering client data or personal data into an unapproved tool is a data incident handled under the Incident Response Plan QIS-IRP-001, and may lead to legal liability under the Personal Data Protection Law.

13. Contact

Request / report	Responsible party	How to reach them
General questions about the policy	GRC Lead	grc@qis.example
Request to approve a new AI tool	GRC Lead	Request form under procedure 1 of QIS-PRC-002
Technical support for AI tools	Chief Technology Officer	Ticketing system
Security reports and incidents	Security Operations and Engineering	security@qis.example — ext. 2100
Using AI on a client's data or system	Head of Service Delivery	The contact named in the contract

RESTRICTED

Request / report	Responsible party	How to reach them
Training or awareness request	GRC Lead	grc@qis.example

14. Review and update

14.1 Review

The GRC Lead reviews this policy every six months in the first year, because AI technology is moving fast, then annually, to confirm it is still suitable, effective and in line with QIS's goals and its clients' requirements.

14.2 Update

This policy is updated after any significant change to QIS's services, clients or tools, after a related incident, or when new legal or regulatory requirements are issued, including the final version of the AI Cybersecurity Guidelines.

15. References

Type	Code	Reference	Issuer
External	AICG-1:2026	AI Cybersecurity Guidelines — guidance document that section 8 is built on	National Cybersecurity Authority
External	AI-First	AI First policy — guidance document that section 9 is built on	Saudi Data and AI Authority
External	ECC-2:2024	Essential Cybersecurity Controls	National Cybersecurity Authority
External	PDPL	Personal Data Protection Law and its implementing regulation	Saudi Data and AI Authority
External	—	AI Ethics Principles	Saudi Data and AI Authority
External	ISO/IEC 42001	AI management system (2023)	International Organization for Standardization
Internal	QIS-PRC-002	AI Usage Procedure	QIS
Internal	QIS-POL-001	Data Protection Policy	QIS
Internal	QIS-RMM-001	Risk Management Methodology	QIS
Internal	QIS-IRP-001	Incident Response Plan	QIS

RESTRICTED

Type	Code	Reference	Issuer
Internal	QIS-CHR-001	Cybersecurity Charter and Organizational Structure	QIS

AICG-1:2026 and the AI First policy are guidance documents, and the NCA guidelines are still a draft published for consultation. They are used as the basis for this policy's clauses and will be updated when final versions are issued. The control and article texts in sections 8 and 9 must be matched against the official documents before version 1.0 is approved.

RESTRICTED